Cyber Security

Module 3: Information Security Management

Exam-Oriented Study Notes

BCA, MAKAUT

Contents

1 Introduction to Information Security Management **2**
1.1 Data vs Information . . . 2
1.2 Information Assets . . . 2
1.3 Need for ISM . . . 2
1.4 Three Pillars of ISM . . . 2
1.5 Important Standards and Frameworks . . . 3

2 Goals of Information Security **3**
2.1 Balancing the Goals . . . 3
2.2 Security Objectives of an Organisation . . . 3

3 ISMS: Information Security Management System **4**
3.1 PDCA Cycle (Working Principle) . . . 4
3.2 ISMS Working Procedure (Step by Step) . . . 4
3.3 Annex A Controls (ISO/IEC 27001:2022) . . . 5
3.4 Benefits of an ISMS . . . 5

4 Security Policies **5**
4.1 Policy Documentation Hierarchy . . . 5
4.2 Types of Security Policies . . . 6
4.3 Common Policies in an Organisation . . . 6
4.4 Characteristics of a Good Policy . . . 6
4.5 Policy Life Cycle . . . 6

5 Risk Management **7**
5.1 Key Terms . . . 7
5.2 Risk Management Process . . . 7
5.3 Risk Assessment Methods . . . 7
5.4 Risk Treatment Options . . . 8

6 Information Security Audit **8**
6.1 Objectives . . . 8
6.2 Types of Audit . . . 9
6.3 Audit Process . . . 9
6.4 Classification of Findings . . . 9
6.5 Audit vs Risk Assessment . . . 9

7 Quick Revision Sheet **11**

1 Introduction to Information Security Management

Definition

Information Security Management (ISM) is the structured process of planning, implementing, monitoring and improving the measures that protect an organisation's **information assets** from threats, so that business objectives are met safely. It covers **people, processes and technology**, not just software tools.

1.1 Data vs Information

Data is raw facts (e.g. marks of students). **Information** is processed, meaningful data (e.g. the class topper list). Information can exist in three **states**: **at rest** (stored), **in transit** (moving across a network) and **in use** (being processed). Each state needs protection.

1.2 Information Assets

Anything of value to the organisation: databases, source code, documents, hardware, software, employees' knowledge, reputation, and intellectual property. Assets are usually **classified** by sensitivity:

Level	Meaning	Example
Public	Safe to share with anyone	Brochure, website content
Internal	For employees only	Circulars, internal phone list
Confidential	Damage if leaked	Customer data, salary records
Restricted / Secret	Severe damage if leaked	Encryption keys, strategic plans

1.3 Need for ISM

- Growing cyber attacks (ransomware, phishing, insider misuse).
- Legal and regulatory requirements (IT Act 2000, Digital Personal Data Protection Act 2023 in India, GDPR for EU data).
- Protecting reputation, customer trust and business continuity.
- Reducing financial loss from breaches and downtime.

1.4 Three Pillars of ISM

Pillar	Role	Examples
People	Awareness, roles and responsibilities	Training, background checks, security officer
Process	Documented, repeatable procedures	Policies, incident response, change management
Technology	Tools that enforce security	Firewall, antivirus, encryption, IAM, backups

1.5 Important Standards and Frameworks

Standard	Purpose
ISO/IEC 27001	Requirements for establishing an ISMS (certifiable)
ISO/IEC 27002	Guidelines and best-practice controls
NIST Cybersecurity Framework	Identify, Protect, Detect, Respond, Recover (and Govern)
COBIT	IT governance and management framework
PCI DSS	Protection of payment card data

Exam Tip

Define ISM using the words *protect, information assets, people-process-technology.* Mention ISO/IEC 27001 early, since later topics (ISMS, audit) are based on it.

Practice Questions

Short Answer: (1) Define ISM. (2) Differentiate data and information. (3) Name the three states of information.

Long Answer: (4) Explain the need and scope of Information Security Management.

2 Goals of Information Security

The primary goals are the **CIA triad**. Modern practice adds further goals.

Goal	Meaning	Example Control
Confidentiality	Only authorised users can access information	Encryption, access control, MFA
Integrity	Information is accurate and not altered improperly	Hashing, digital signatures, audit logs
Availability	Information is accessible when needed	Backups, redundancy, DR plan
Authenticity	Genuine source and identity is verified	Passwords, certificates, biometrics
Accountability	Actions can be traced to a person or system	Logging, unique user IDs
Non-repudiation	Sender cannot deny sending a message	Digital signatures, timestamps
Privacy	Personal data is collected and used lawfully	Consent, data minimisation, masking

2.1 Balancing the Goals

Security goals sometimes conflict. Very strict confidentiality (many approval steps) can reduce availability; heavy encryption can slow systems. ISM aims to find the right **balance** based on business needs and risk.

2.2 Security Objectives of an Organisation

Prevent incidents (controls), **detect** them quickly (monitoring), **respond** effectively (incident response) and **recover** (backup and continuity).

Exam Tip

Write CIA first with one example each, then add 2–3 extra goals (authenticity, accountability, non-repudiation). This gives a complete answer for 5 marks.

Practice Questions

Short Answer: (1) What is accountability? (2) Give one control each for C, I and A.
Long Answer: (3) Explain the goals of information security with examples. (4) Why do security goals sometimes conflict?

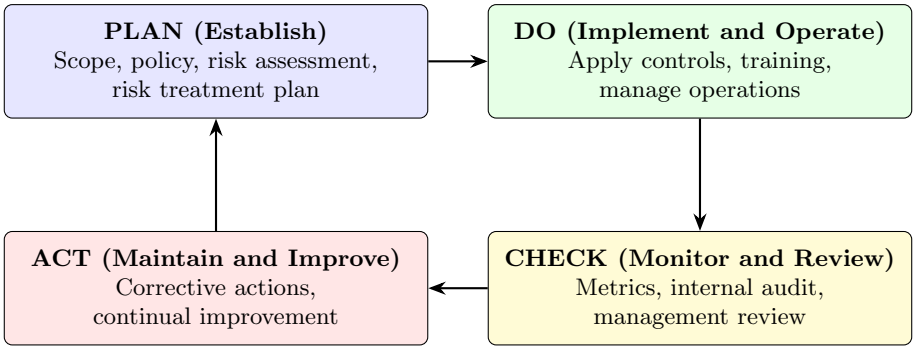
3 ISMS: Information Security Management System

Definition

An **ISMS** is a systematic framework of policies, processes, roles and controls used to manage and continually improve an organisation's information security. The international standard is **ISO/IEC 27001**, and an organisation can be formally **certified** against it.

3.1 PDCA Cycle (Working Principle)

ISMS works as a continuous **Plan–Do–Check–Act** loop, which keeps security up to date as threats and business needs change.



3.2 ISMS Working Procedure (Step by Step)

1. **Management commitment:** top management approves the ISMS, provides resources and assigns roles.
2. **Define scope:** decide which departments, locations, systems and information are covered.
3. **Establish information security policy:** high-level statement of objectives and direction.
4. **Risk assessment:** identify assets, threats and vulnerabilities; estimate risk levels.
5. **Risk treatment:** choose to mitigate, avoid, transfer or accept each risk; prepare the **risk treatment plan**.
6. **Select controls and prepare the Statement of Applicability (SoA):** lists the Annex A controls chosen, with the reason for including or excluding each.
7. **Implement controls:** technical (firewall, encryption), physical (access cards, CCTV) and administrative (procedures).
8. **Training and awareness:** make all staff aware of their responsibilities.
9. **Monitor and measure:** track incidents, logs and performance metrics.
10. **Internal audit and management review:** verify that the ISMS works and meets the standard.
11. **Corrective action and continual improvement:** fix non-conformities and update the ISMS.

12. **Certification audit:** an external certification body audits the ISMS (Stage 1 documentation review, Stage 2 implementation audit).

3.3 Annex A Controls (ISO/IEC 27001:2022)

The 2022 version lists **93 controls** grouped into four themes:

Theme	Controls	Examples
Organisational	37	Policies, asset management, supplier security
People	8	Screening, awareness, remote working
Physical	14	Secure areas, equipment protection
Technological	34	Access control, cryptography, logging, backup

(The older 2013 version had 114 controls in 14 domains.)

3.4 Benefits of an ISMS

Systematic risk management, legal compliance, customer confidence, lower incident cost, and a competitive advantage through certification.

Exam Tip

Draw the PDCA diagram and map the ISMS steps to Plan, Do, Check and Act. Mention **Statement of Applicability** and **continual improvement**, as these are the keywords examiners look for.

Practice Questions

Short Answer: (1) What is an ISMS? (2) What is the Statement of Applicability? (3) Expand PDCA.

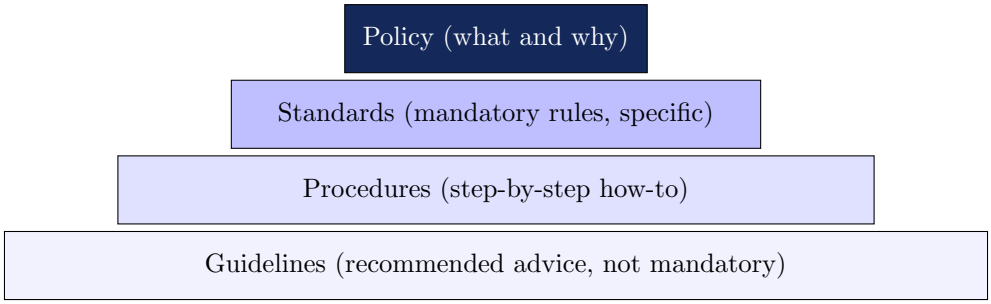
Long Answer: (4) Explain the working procedure of an ISMS with the PDCA cycle. (5) Describe ISO/IEC 27001 and its benefits.

4 Security Policies

Definition

A **security policy** is a formal, written statement approved by management that defines **what** is expected of people and systems to protect information. It sets rules, responsibilities and consequences of violation.

4.1 Policy Documentation Hierarchy



Document	Nature	Example
Policy	High-level, management direction	"All sensitive data must be protected."
Standard	Mandatory technical requirement	Passwords must be at least 12 characters
Procedure	Detailed steps	Steps to create or disable a user account
Guideline	Optional recommendation	Tips for choosing a memorable passphrase

4.2 Types of Security Policies

Type	Description	Examples
Enterprise (Programme) Policy	Overall policy for the whole organisation; sets direction and responsibilities	Information Security Policy
Issue-Specific Policy	Covers a particular topic or technology	Acceptable Use, Email, Password, BYOD, Remote Access, Social Media
System-Specific Policy	Rules for one particular system	Firewall rule policy, database access policy

4.3 Common Policies in an Organisation

- **Acceptable Use Policy (AUP):** what employees may and may not do with company systems.
- **Password Policy:** length, complexity, expiry, no reuse, MFA.
- **Access Control Policy:** least privilege, need-to-know, role-based access.
- **Backup and Recovery Policy:** frequency, storage, restore testing.
- **Incident Response Policy:** how to report, handle and learn from incidents.
- **BYOD Policy:** using personal devices for work securely.
- **Data Classification and Retention Policy.**

4.4 Characteristics of a Good Policy

Clear and concise, approved by top management, enforceable, realistic, aligned with law and business goals, communicated to everyone, and **reviewed regularly**.

4.5 Policy Life Cycle

Develop → **Approve** → **Communicate and train** → **Enforce** → **Review and update** (at least yearly or after major incidents).

Exam Tip

Learn the hierarchy **Policy** > **Standard** > **Procedure** > **Guideline**. The difference between *standard* (mandatory) and *guideline* (optional) is a common 2-mark question.

Practice Questions

Short Answer: (1) Define security policy. (2) Differentiate standard and guideline. (3) What is an Acceptable Use Policy?

Long Answer: (4) Explain the types of security policies with examples. (5) Describe the characteristics and life cycle of a good security policy.

5 Risk Management

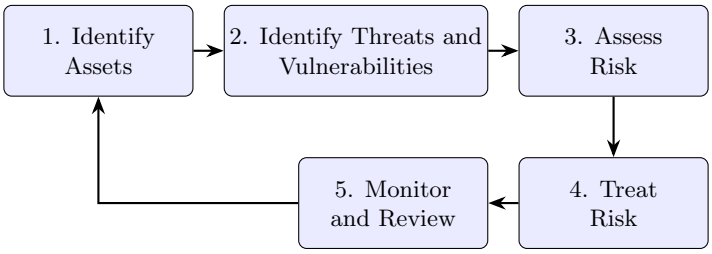
Definition

Risk management is the process of identifying, assessing and controlling risks to information assets so that they stay within the level the organisation is willing to accept.

5.1 Key Terms

Term	Meaning
Asset	Anything valuable to be protected
Threat	Potential cause of harm (hacker, malware, flood, fire)
Vulnerability	Weakness that a threat can exploit (unpatched server)
Likelihood	Chance that the threat will occur
Impact	Damage if it occurs
Risk	Likelihood × Impact (combination of threat, vulnerability and asset value)
Residual risk	Risk remaining after controls are applied
Risk appetite	Amount of risk the organisation is ready to accept

5.2 Risk Management Process



5.3 Risk Assessment Methods

- **Qualitative:** uses ratings such as Low, Medium, High based on judgement; quick and easy.
- **Quantitative:** uses numerical values and money; more precise but needs good data.

Qualitative Risk Matrix (Likelihood × Impact)

Likelihood \ Impact	Low (1)	Medium (2)	High (3)
High (3)	3 Medium	6 High	9 Critical
Medium (2)	2 Low	4 Medium	6 High
Low (1)	1 Low	2 Low	3 Medium

Quantitative Formulas

$$\text{SLE (Single Loss Expectancy)} = \text{AV} \times \text{EF}$$
$$\text{ALE (Annual Loss Expectancy)} = \text{SLE} \times \text{ARO}$$

where **AV** = asset value, **EF** = exposure factor (percentage of asset lost in one incident) and **ARO** = annualised rate of occurrence (expected incidents per year).

Worked Example. A server is worth Rs. 10,00,000. A flood would damage 40% of it, and floods are expected once in 5 years.

- SLE = 10,00,000 × 0.40 = Rs. 4,00,000
- ARO = 1/5 = 0.2
- ALE = 4,00,000 × 0.2 = Rs. 80,000 per year

Cost-benefit check: if a safeguard (e.g. a raised server room) costs Rs. 30,000 per year and reduces ALE to Rs. 20,000, then

Value of safeguard = (ALE before−ALE after)−annual cost = (80,000−20,000)−30,000 = Rs. 30,000

Since the value is positive, the safeguard is **worth implementing**.

5.4 Risk Treatment Options

Option	Meaning	Example
Mitigate (Reduce)	Apply controls to lower likelihood or impact	Install firewall, patch systems
Avoid	Stop the risky activity	Do not store card data at all
Transfer (Share)	Shift the risk to a third party	Cyber insurance, outsourcing
Accept (Retain)	Accept the risk knowingly when cost of control is higher than loss	Minor risks within appetite

Remember

Risk can never be reduced to zero. After treatment, the **residual risk** must be formally accepted by management, and risks must be **reviewed regularly**, as threats keep changing.

Exam Tip

Numericals on SLE and ALE are very common: write the formula, substitute values, and finish with a one-line conclusion (worth it or not). For theory answers, always list the four treatment options.

Practice Questions

Short Answer: (1) Define risk and residual risk. (2) Differentiate qualitative and quantitative assessment. (3) List four risk treatment options.

Numerical: (4) Asset value Rs. 5,00,000, exposure factor 60%, occurs twice a year. Find SLE and ALE.

Long Answer: (5) Explain the risk management process with a diagram.

6 Information Security Audit

Definition

An **information security audit** is a systematic, independent and documented examination of an organisation's information systems, policies and controls to check whether they are **effective, compliant** with standards and laws, and properly implemented. It is based on gathering and evaluating **evidence**.

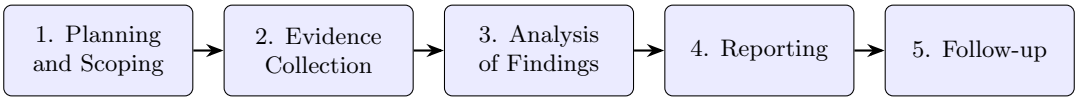
6.1 Objectives

Verify compliance with policies, laws and standards; find weaknesses and gaps; confirm controls work as intended; support management decisions; and provide assurance to customers and regulators.

6.2 Types of Audit

Type	Description
Internal audit	Done by the organisation's own team (first party)
External audit	Done by an independent outside auditor (second or third party, e.g. certification body)
Compliance audit	Checks conformity with ISO 27001, PCI DSS, laws
Technical audit	Tests systems directly: vulnerability assessment, penetration testing, configuration review
Physical security audit	Checks locks, CCTV, access to server rooms

6.3 Audit Process



1. **Planning:** define objectives, scope, criteria (standard or policy), schedule and audit team.
2. **Evidence collection:** *interviews*, *observation*, *document and log review*, and *technical testing* (scans, configuration checks).
3. **Analysis:** compare what exists with what is required; identify gaps and rate their severity.
4. **Reporting:** present findings, risks and recommendations to management.
5. **Follow-up:** verify that corrective actions were completed.

6.4 Classification of Findings

- **Major non-conformity:** a requirement is not met at all, or a serious control failure.
- **Minor non-conformity:** a small lapse that does not by itself defeat the control.
- **Observation / Opportunity for improvement:** a suggestion rather than a failure.

6.5 Audit vs Risk Assessment

Basis	Audit	Risk Assessment
Question answered	"Are controls in place and working?"	"What could go wrong and how bad?"
Focus	Compliance and effectiveness	Threats, vulnerabilities, impact
Performed by	Independent auditor	Risk or security team
Output	Audit report with findings	Risk register and treatment plan

Case Study: Security Audit of a College Student-Records System

Scenario: A college stores admission and exam records in a web portal. After a complaint that marks could be changed by outsiders, management orders an independent audit of the portal and its server room against the college's security policy and ISO/IEC 27001 good practice.

Audit approach:

- **Planning:** scope = portal, database server, admin staff, server room.
- **Evidence:** interviewed IT staff, reviewed policies and logs, inspected the server room, ran a vulnerability scan on the portal.

Findings:

Finding	Severity	Recommendation
Admin account shared by four staff with a weak password	Major	Unique IDs, strong passwords, MFA
Server and web software unpatched for over a year	Major	Patch management process, monthly updates
Backups taken, but restore never tested	Minor	Quarterly restore tests, offsite copy
Logs kept but never reviewed	Minor	Weekly log review, central logging
Server room door left open; no visitor register	Minor	Access card, visitor log, CCTV
No written security policy known to staff	Major	Approve policy and run awareness training

Outcome: the report was given to management with a corrective action plan and deadlines. A **follow-up audit** after three months confirmed that the major issues were closed.
Mapping to CIA: shared admin account and no logging affected *confidentiality and integrity* (marks could be altered); missing restore tests affected *availability*.
Lesson: most findings were weak basics (passwords, patches, policy), not advanced attacks. Regular audits catch these before attackers do.

Exam Tip

For audit answers, write the five-phase process and the types of audit. In case studies, present findings in a table with **severity and recommendation**, then mention the follow-up audit and map the findings to CIA.

Practice Questions

Short Answer: (1) Define information security audit. (2) Differentiate internal and external audit. (3) What is a non-conformity?

Long Answer: (4) Explain the information security audit process in detail. (5) Describe an audit of an organisation's information system with findings and recommendations.

7 Quick Revision Sheet

Topic	Remember
ISM	Protecting information assets using people, process and technology
Information states	At rest, in transit, in use
Goals	C, I, A + authenticity, accountability, non-repudiation, privacy
ISMS standard	ISO/IEC 27001 (requirements); 27002 (guidelines)
ISMS cycle	Plan → Do → Check → Act (continual improvement)
Annex A (2022)	93 controls in 4 themes: 37, 8, 14, 34
Policy hierarchy	Policy > Standard > Procedure > Guideline
Policy types	Enterprise, Issue-specific, System-specific
Risk	Likelihood × Impact
Formulas	SLE = AV × EF; ALE = SLE × ARO
Treatment	Mitigate, Avoid, Transfer, Accept
Audit process	Plan → Evidence → Analysis → Report → Follow-up
Finding types	Major, Minor, Observation